Кабинет клиники: что требует закон и что закрывает портал

Максимальная версия личного кабинета медицинской организации · три профиля: малая, средняя, сеть · пакет Базовый — только закон, пакет Стандарт — закон и лучшие практики непрерывности

Схема 2 к ваппейджеру направления
Версия 1 · 20.10.2026
Нормы проверены по текстам актов 20.10.2026

1 Три профиля клиники — что дает закон

	Малая	Средняя	Сеть
Пример	1 адрес, до 10 ПК, облачная МИС	10–30 ПК, сервер с МИС, рентген	3+ филиала, 50+ ПК, ЛИС, PACS
Пациентов в базе	до 100 тыс.	до 100 тыс.	больше 100 тыс.
УЗ при угрозах 3-го типа	**УЗ-3** ПП 1119 п. 11 «в»	**УЗ-3**	**УЗ-2** п. 10 «е»
Мер ФСТЭК в базе	**41**	**41**	**66**
Субъект КИИ	да	да	да
Объекты по 360-р	МИС (п. 3), обмен с ЕГИСЗ (п. 5)	плюс рентген (п. 8)	плюс ЛИС (п. 7)
Категория	как правило нет	как правило нет	возможна III: порог 1 пострадавший
Указ 250	да	да	да
Требований в карте	**33**	**33**	**35**

Что показала разметка

- По закону малая и средняя клиника одинаковы: УЗ-3 и субъект КИИ, 33 требования. Разница — в объеме работ.
- Сеть добавляет 25 мер ФСТЭК (УЗ-2) и шанс значимого объекта.
- Указ 250 касается любой клиники — субъекта КИИ: заместитель ГД по информационной безопасности (ИБ), исполнитель — только лицензиат ФСТЭК по технической защите (ТЗКИ). Лицензия партнера — условие входа даже в Базовый.
- Сертифицированный межсетевой экран и облачные копии уходят в Стандарт.

Цена бездействия (КоАП, юрлицо)

- Нет уведомления в РКН — 100–300 тыс. руб. (13.11 ч. 10).
- Не сообщили об утечке — 1–3 млн; утечка данных о здоровье — 10–15 млн; повторная — 1–3 % выручки, от 25 млн (ч. 11, 16, 18).
- Нет сведений о категорировании во ФСТЭК — 50–100 тыс.; нет информации в ГосСОПКА — 100–500 тыс. (19.7.15).
- Нарушение правил эксплуатации объекта КИИ — 100–500 тыс. (13.12.2, с 20.04.2026).

2 Матрица: требование закона → модуль кабинета

35 требований · М — малая, С — средняя · Мод. — номер модуля из блока 5

Персональные данные (ПДн): 152-ФЗ, ПП 1119, приказ ФСТЭК 21, приказы РКН

№	Требование	Норма	М	С	Сеть	Мод.	Покрытие
1	Ответственный за организацию обработки ПДн	152-ФЗ ст. 18.1 ч. 1 п. 1	●	●	●	2	кабинет
2	Политика и локальные акты, политика опубликована	ст. 18.1 ч. 1 п. 2, ч. 2	●	●	●	2	кабинет
3	Уведомление РКН до начала обработки, изменения до 15 числа	ст. 22, ч. 7	●	●	●	2, 4	+ клиника
4	Оценка вреда субъектам	ст. 18.1 п. 5; приказ РКН 178	●	●	●	2	кабинет
5	Модель угроз и уровень защищенности	ст. 19 ч. 2 п. 1–2; ПП 1119 п. 7–11	●	●	●	1, 2	кабинет
6	Ответственный за безопасность ПДн в системе	ПП 1119 п. 14	●	●	●	2	кабинет
7	Режим помещений	ПП 1119 п. 13 «а»	●	●	●	7	+ клиника
8	Учет и сохранность носителей	п. 13 «б»; ЗНИ.8	●	●	●	7	кабинет
9	Перечень лиц с доступом, утвержден ГД	п. 13 «в»	●	●	●	6	кабинет
10	Антивирус на ПК и серверах A	приказ ФСТЭК 21: АВ3.1–2	●	●	●	5	+ клиника
11	Фильтрация на границе сети, защита каналов и Wi-Fi	УПД.3; ЗИС.3; ЗИС.20	●	●	●	5	+ клиника
12	Учетные записи, пароли, удаленный доступ	ИАФ.1, 3–6; УПД.1–6, 10, 11, 13–16	●	●	●	6	+ клиника
13	Журнал событий безопасности A	РСБ.1–3, 7	●	●	●	5	+ клиника
14	Обновления и уязвимости A	АНЗ.1–4	●	●	●	5	+ клиника
15	Управление конфигурацией	УКФ.1–4	●	●	●	5	кабинет
16	Сертифицированные средства, если их требует модель угроз	ПП 1119 п. 13 «г»; приказ 21 п. 12	◐	◐	◐	5	+ клиника
17	Ознакомление и обучение работников	ст. 18.1 ч. 1 п. 6	●	●	●	9	кабинет
18	Внутренний контроль; контроль и оценка эффективности раз в 3 года	ст. 18.1 п. 4; ПП 1119 п. 17; приказ 21 п. 6	●	●	●	10	кабинет
19	Ответ пациенту и РКН за 10 рабочих дней (+5)	ст. 20	●	●	●	7	кабинет
20	Согласия отдельным документом, кроме лечения	ст. 9 (с 01.09.2025); ст. 10 ч. 2 п. 4	●	●	●	2	кабинет
21	Инцидент с ПДн: РКН за 24 и 72 часа	ст. 21 ч. 3.1; приказ ФСБ 77	●	●	●	8	+ клиника
22	Уничтожение ПДн: сроки, акт, выгрузка журнала, средство с оценкой соответствия	ст. 21; ст. 19 ч. 2 п. 3.1; приказ РКН 179	●	●	●	7	+ клиника
23	Восстановление ПДн: резервные копии и тест	ст. 19 ч. 2 п. 7; сеть: ОДТ.4–5	●	●	●	11	+ клиника
24	Базы данных в России, договор поручения с облачной МИС	ст. 18 ч. 5; ст. 6 ч. 3	●	●	●	2, 5	кабинет
25	УЗ-2: обнаружение вторжений, сегменты, целостность, инциденты, доступ к журналу	СОВ.1–2; ЗИС.17; ОЦЛ.1; ИНЦ.1–6; ПП 1119 п. 15	–	–	●	5, 8	+ клиника

КИИ: 187-ФЗ, ПП 127, 360-р, приказы ФСБ, Указ 250

№	Требование и норма	М	С	Сеть	Мод.	Покрытие
26	Комиссия, перечень типовых объектов, акт категорирования 187-ФЗ ст. 7; ПП 127; 360-р п. 3, 5, 7, 8	●	●	●	3	кабинет
27	Сведения во ФСТЭК за 10 рабочих дней, в том числе «без категории» ст. 7 ч. 4–5; ПП 127 п. 17	●	●	●	3, 4	+ клиника
28	Пересмотр при изменениях и раз в 5 лет ПП 127 п. 19(1), 19(2), 21	●	●	●	1, 10	кабинет
29	Инцидент или атака: НКЦКИ за 24 часа ст. 9 ч. 2 п. 1; приказ ФСБ 547	●	●	●	8	+ клиника
30	Получать информацию об атаках с cert.gov.ru приказ ФСБ 539	●	●	●	10	кабинет
31	Содействие ФСБ, работа средств ГосСОПКА ст. 9 ч. 2 п. 2–3	●	●	●	8	+ клиника
32	Заместитель ГД по ИБ с профильным образованием, подразделение или функции Указ 250 п. 1 «а», «б»; ПП 1272	●	●	●	3, 9	+ клиника
33	Подрядчик по ИБ — лицензиат ТЗКИ, по реагированию — аккредитованный центр Указ 250 п. 1 «в», «г»	●	●	●	5	+ клиника
34	Средства защиты из недружественных стран запрещены с 01.01.2025 Указ 250 п. 6	●	●	●	5	кабинет
35	Значимый объект: система безопасности, меры ФСТЭК, российское ПО и ПАК, ГосСОПКА, план реагирования за 90 дней, НКЦКИ за 3 часа ст. 9 ч. 3, ст. 10; приказы ФСТЭК 235, 239; ПП 1912; приказы ФСБ 547, 548	–	–	◐	3, 12	вне

Малая и средняя клиника
33 требования
кабинет 17 · + клиника 16 · вне 0

Сеть
35 требований
кабинет 17 · + клиника 17 · вне 1

Применимость: ● действует · ◐ при условии (модель угроз, категория) · – не применяется
кабинет — кабинет сам формирует документ, запись или напоминание
+ клиника — кабинет готовит и ведет по шагам; подпись и отправку делает ГД, замки, установку и настройку средств — инженер-лицензиат
вне — работа вне кабинета; кабинет дает шаблоны, сроки и помощь
A — в Стандарте агент на ПК переводит строки 10, 13, 14 на автоконтроль

Тот же принцип для других средств
Антивирус обязателен всегда (АВ3.1–2) и российский. Защита от несанкционированного доступа (НСД) — по модели угроз. Уничтожение ПДн в электронном виде — средством с функцией уничтожения, прошедшим оценку соответствия (ст. 19 ч. 2 п. 3.1, с 08.08.2024).

3 Межсетевой экран и закон

1. **Всегда при УЗ-3 и УЗ-2:** фильтрация потоков на границе сети (мера УПД.3), защита каналов (ЗИС.3) и Wi-Fi (ЗИС.20), приказ ФСТЭК 21. Подходит любой межсетевой экран, в том числе встроенный в роутер.
2. **Субъект КИИ:** с 01.01.2025 средства защиты из недружественных стран запрещены (Указ 250 п. 6). Экран — российский или из дружественной страны.
3. **Сертифицированный экран** (класс 6 для УЗ-3, класс 5 для УЗ-2) обязателен, когда модель угроз закрывает угрозу из интернета сертифицированным средством (ПП 1119 п. 13 «г», приказ 21 п. 12), и на значимом объекте КИИ.
4. **Разъяснений** ФСТЭК и РКН за 2023–2026 годы по коммерческим клиникам нет. Позиция практиков (Контур, 2026): для УЗ-3 допустимы любые средства, если они нейтрализуют актуальные угрозы.

Базовый
Российский экран без сертификата и обоснование в модели угроз.

Стандарт
Сертифицированный экран класса 6: спор с проверяющим снят заранее.

4 Как это видит главврач

Ввел ФИО и реквизиты	→ весь комплект приказов, перечней и писем собран и ждет подписи ЭП
Открыл филиал или новую систему	→ задачи: изменения в РКН до 15 числа, пересмотр категорирования
Внес ПК и лицензии	→ напоминания за 30, 14 и 3 дня, счет на продление готов
Админ отметил копию	→ календарь зеленый; 7 дней без отметки — сигнал ГД
Ввел 5 главных рисков C	→ анализ влияния и план восстановления собраны автоматически
Сбой или атака	→ красная кнопка: таймер 24 часа, уведомления в НКЦКИ и РКН готовы
Пришла проверка	→ папка со всеми доказательствами за минуту

5 14 модулей кабинета

уровни автоматизации: 1 — отметки, 2 — напоминания и предзаполнение, 3 — автосбор агентом

1 Профиль и карта требований
Базовый · уровни 1-2
Мастер на 20 вопросов: адреса, ПК, серверы, МИС, ЛИС, рентген, пациенты, сайт. Кабинет сам определяет УЗ, объекты КИИ по 360-р и строит карту требований с процентом выполнения. Изменение профиля создает задачи.
Закрывает строки: 5, 28

2 Документы ПДн
Базовый · уровни 1-2
ФИО главврача и реквизиты подставляются везде: приказы об ответственных, политика с публикацией по постоянной ссылке, положение, перечни, акт УЗ, модель угроз, оценка вреда, согласия, договор поручения, уведомление в РКН.
Закрывает строки: 1–6, 20, 24

3 Документы КИИ и письма
Базовый · уровни 1-2
Приказ о комиссии, перечень типовых объектов с автоподбором из 360-р, акт категорирования с расчетом показателей, сведения во ФСТЭК, письмо за подписью ГД, контроль 30 дней проверки ФСТЭК, приказы по Указу 250.
Закрывает строки: 26, 27, 32, 35

4 Подпись и отправка
Базовый · уровни 2
Очередь документов на подпись ГД с электронной подписью (ЭП). Отметки об отправке в РКН, ФСТЭК и НКЦКИ, входящие ответы в карточке. Каждое действие сразу становится доказательством.
Закрывает строки: 3, 27

5 Реестр техники и средств защиты
Базовый · + Стандарт · уровни 1-2-3
ПК, серверы, сеть, ПО. Антивирус и средства защиты с датами лицензий, сертификатами ФСТЭК и страной производителя. Напоминания за 30, 14 и 3 дня. В Стандарте агент собирает данные сам.
Закрывает строки: 10–16, 24, 25, 33, 34

6 Доступы и учетные записи
Базовый · уровни 1-2
Перечень лиц с доступом, роли в МИС, чек-лист приема и увольнения: выдать или отозвать доступ в день события. Сверка учетных записей раз в квартал.
Закрывает строки: 9, 12

7 Журналы и доказательства
Базовый · уровни 1-2
Носители, помещения, ознакомление, внутренний контроль. Обращения пациентов с таймером 10+5 рабочих дней. Уничтожение ПДн с актом и выгрузкой журнала, хранение 3 года.
Закрывает строки: 7, 8, 19, 22

8 Инцидент: красная кнопка
Базовый · уровни 2
Пошаговый сценарий с таймерами: НКЦКИ за 24 часа (значимый объект — за 3), РКН за 24 и 72 часа. Уведомления предзаполнены, ГД подписывает с телефона.
Закрывает строки: 21, 25, 29, 31

9 Люди и обучение
Базовый · + Стандарт · уровни 1-2
Курс на 20 минут, тест, электронный лист ознакомления, инструктаж новичка, повтор раз в год, учет подготовки заместителя по ИБ. В Стандарте — учебные фишинговые письма.
Закрывает строки: 17, 32

10 Календарь регулятора
Базовый · уровни 2
Все сроки на одном экране: контроль, оценка эффективности, пересмотр категорирования, изменения в РКН, продления. Лента: новое требование → что меняется для клиники → шаблоны обновлены.
Закрывает строки: 18, 28, 30

11 Резервные копии
Базовый · + Стандарт · уровни 1-2-3
Календарь копий, отметка «копия сделана»: кто, когда, куда; тест восстановления с актом. Базовый — тест раз в год. Стандарт — правило 3-2-1, облако, автоотметка от хранилища, тест раз в квартал.
Закрывает строки: 23

12 Непрерывность
только Стандарт · уровни 1-2
Сценарии: МИС недоступна, шифровальщик, нет света, ушел админ → анализ влияния (BIA) → план восстановления собирается сам: бумажный режим, бланки, контакты. Учения раз в полгода.
Закрывает строки: сверх закона; значимый объект — 35

13 Панель руководителя
Базовый · + Стандарт · уровни 2
Процент соответствия, красные сроки, что подписать, штрафы под риском в рублях. В Стандарте — отчет ГД на одну страницу раз в месяц и сравнение филиалов.
Закрывает строки: обзор всех строк

14 Папка для проверки
Базовый · уровни 2
Одна кнопка: PDF и архив со всеми документами, журналами, актами и реестрами на дату. Ответ на вопрос проверяющего «что у вас есть по КИИ и ПДн».
Закрывает строки: доказательства по всем строкам

Как читать
Номер модуля — колонка «Мод.» в матрице.
Базовый — модуль нужен для закона.
+ Стандарт — в Стандарте модуль расширяется.
Только Стандарт — сверх закона, лучшие практики непрерывности.

6 Базовый и Стандарт

Базовый
только закон

- 13 модулей в объеме закона: 33 требования, у сети 35
- Российский межсетевой экран и обоснование в модели угроз
- Российский антивирус на всех ПК и серверах
- Копия и тест восстановления раз в год
- Автоматизация уровней 1 и 2

Стандарт
закон и лучшие практики непрерывности

- Модуль 12: риски → анализ влияния → план восстановления → учения раз в полгода
- Сертифицированный экран класса 6, у сети — класса 5
- Копии по правилу 3-2-1 с облаком, тест раз в квартал
- Агент на ПК и интеграции: антивирус, хранилище, МИС
- Фишинг-тренировки, отчет ГД, сравнение филиалов

1 · Отметки
Мастер, генерация документов, ручные отметки. Запуск.

2 · Напоминания
Сроки в Telegram и почте, письма в госорганы, подпись ЭП.

3 · Автосбор
Агент на ПК, консоль антивируса, хранилище копий, МИС.

Условие для уровня 3 и всего направления
Мониторинг ИБ и установка средств защиты — лицензируемые работы (ПП 79 п. 4 «в», «е»). У клиники — субъекта КИИ исполнитель по ИБ только лицензиат ТЗКИ (Указ 250 п. 1 «в»).

Нормы: 152-ФЗ (ред. 26.07.2026), ПП 1119, приказ ФСТЭК 21 (ред. 2020), требования ФСТЭК к межсетевым экранам (2016), приказы РКН 178, 179; 187-ФЗ (ред. 58-ФЗ), ПП 127 (ред. ПП 1281, 1762), распоряжение 360-р, приказы ФСБ 77, 539, 547, 548; Указ 250, ПП 1272, ПП 79; КоАП 13.11, 13.12.2, 19.7.15.

Допущения: угрозы 3-го типа; проект приказа ФСТЭК взамен приказа 21 на 20.10.2026 не принят; отраслевые особенности категорирования для здравоохранения не утверждены.